

Data Governance & Privacy Policy v1.0

AI-Powered Healthcare Platform

Document Control

- **Version:** 1.0
 - **Date:** August 2025
 - **Status:** Implementation Ready
 - **Classification:** Data Governance & Privacy
-

1. Executive Summary

This document establishes comprehensive data governance policies and procedures for the Sarthi AI-powered healthcare platform. It ensures HIPAA compliance, patient privacy protection, and responsible data management across all platform operations, including AI/ML processing and multi-tenant architecture.

Governance Objectives

- **HIPAA Compliance** - Full adherence to Privacy and Security Rules
 - **Patient Privacy Protection** - Safeguarding PHI across all platform operations
 - **Data Quality Assurance** - Maintaining accurate, complete, and timely data
 - **Regulatory Compliance** - Meeting federal, state, and international requirements
 - **Ethical AI/ML** - Responsible use of patient data for AI model training and inference
-

2. Data Classification Framework

2.1 Data Categories

yaml

Protected Health Information (PHI):

Definition: Any health information that can identify an individual

Examples:

- Patient names, addresses, phone numbers
- Medical record numbers
- Social Security numbers
- Health plan beneficiary numbers
- Biometric identifiers
- Full face photographic images
- Clinical notes and observations
- Laboratory results
- Diagnostic images and reports

Sensitivity Level: Critical

Encryption: Required at rest and in transit

Access Controls: Role-based, logged, audited

Retention: As per state/federal requirements

Business Associate Information:

Definition: Data related to healthcare providers and business partners

Examples:

- Provider credentials and licenses
- Practice management data
- Billing and payment information
- Insurance verification data
- Quality metrics and reporting

Sensitivity Level: High

Encryption: Required at rest and in transit

Access Controls: Role-based access

Retention: 7 years minimum

Technical and Operational Data:

Definition: System-generated data for platform operations

Examples:

- Application logs (de-identified)
- Performance metrics
- Security event logs
- System configuration data
- AI model training metadata

Sensitivity Level: Medium

Encryption: Required for sensitive operations data

Access Controls: Technical team access

Retention: 3 years for audit purposes

Public Information:

Definition: Non-sensitive data approved for public access

Examples:

- Marketing materials
- Public documentation
- Non-identifying research data
- Anonymized statistical reports

Sensitivity Level: Low

Encryption: Not required but recommended

Access Controls: General access controls

Retention: Business requirement driven

2.2 Data Lifecycle Management

yaml

Data Creation:

Collection Standards:

- Minimum necessary principle
- Purpose limitation
- Data quality validation
- Source system verification
- Patient consent verification

Initial Processing:

- Automatic data classification
- Encryption application
- Access control assignment
- Audit trail initiation
- Data quality scoring

Data Processing:

Usage Controls:

- Purpose-bound processing
- Processing log maintenance
- Data transformation tracking
- Quality monitoring
- Consent compliance validation

AI/ML Processing:

- De-identification before training
- Model bias monitoring
- Federated learning protocols
- Differential privacy application
- Model explainability requirements

Data Storage:

Retention Policies:

- **PHI**: State-specific requirements (typically 7-10 years)
- **Business data**: 7 years for financial records
- **Technical logs**: 3 years for audit purposes
- **AI training data**: As per model lifecycle

Storage Requirements:

- Encrypted at rest (AES-256)
- Geographic location restrictions
- Backup and recovery procedures
- Archive and retrieval processes
- Secure disposal protocols

Data Destruction:

Disposal Standards:

- Secure deletion verification
- Certificate of destruction
- Audit trail documentation
- Backup media destruction
- Third-party disposal validation

Triggers:

- Retention period expiration
- Patient request for deletion
- Legal hold release
- Business requirement changes
- Security incident response

3. HIPAA Privacy Compliance

3.1 Privacy Rule Implementation

yaml

Minimum Necessary Standard:

Access Controls:

- Role-based access to PHI
- Least privilege principle
- Just-in-time access for specific cases
- Automatic access expiration
- Regular access reviews

Data Sharing:

- Purpose-limited sharing
- Minimum dataset identification
- Recipient verification
- Sharing agreement requirements
- Usage monitoring and logging

Uses and Disclosures:

Treatment:

- Healthcare provider access
- Care coordination
- Consultation and referrals
- Emergency care situations
- Continuity of care

Payment:

- Insurance verification
- Claims processing
- Billing and collection
- Payment processing
- Revenue cycle management

Healthcare Operations:

- Quality assessment
- Population health management
- Business intelligence
- Compliance monitoring
- Performance improvement

Required Disclosures:

Patient Access:

- Right to access PHI
- Designated record set access
- Electronic access requirements
- **Response timeframe:** 30 days

- Fee limitations

HHS Investigations:

- Compliance investigations
- Enforcement actions
- Audit requests
- Complaint investigations
- Legal proceedings

3.2 Individual Rights Implementation

yaml

Right to Access:

Implementation:

- Patient portal access
- Downloadable health records
- API access for patients
- Third-party app integration
- Mobile access capabilities

Technical Requirements:

- Electronic format provision
- Structured data formats (FHIR)
- Searchable content
- Export functionality
- Print capabilities

Right to Amend:

Process:

- Amendment request portal
- Clinical review workflow
- Provider approval process
- Notification procedures
- Audit trail maintenance

Implementation:

- 60-day response requirement
- Reason documentation
- Patient notification
- Third-party notifications
- Record correction procedures

Right to Restrict:

Capabilities:

- Processing restrictions
- Disclosure limitations
- Access controls
- Communication preferences
- Provider notifications

Technical Implementation:

- Flag-based restrictions
- Workflow integration
- Override procedures
- Audit logging

- Compliance monitoring

Right to Accounting:

Disclosure Tracking:

- Comprehensive disclosure logs
- Purpose documentation
- Recipient identification
- Date and time stamps
- Data element tracking

Reporting:

- 6-year disclosure history
- Searchable disclosure records
- Export capabilities
- Exception reporting
- Patient-friendly formats

3.3 Patient Consent Management

yaml

Consent Collection:

Consent Types:

- Treatment consent
- Data sharing consent
- Marketing communications
- Research participation
- AI/ML data usage

Collection Methods:

- Digital consent forms
- Electronic signatures
- Biometric verification
- Multi-factor authentication
- Witnessed consent procedures

Consent Storage:

Requirements:

- Tamper-proof storage
- Version control
- Audit trail maintenance
- Easy retrieval
- Long-term preservation

Technical Implementation:

- Blockchain-based consent ledger
- Encrypted consent storage
- Digital signature verification
- Consent metadata tracking
- Integration with EHR systems

Consent Management:

Ongoing Management:

- Consent withdrawal procedures
- Granular consent controls
- Consent expiration handling
- Renewal notifications
- Preference management

Operational Procedures:

- Staff training on consent
- Consent verification workflows
- Exception handling procedures

- Dispute resolution processes
- Compliance monitoring

4. Data Security and Access Controls

4.1 Multi-Tenant Data Isolation

```
yaml
```

Tenant Isolation Strategy:

Database Level:

- Tenant-specific schemas
- Row-level security (RLS)
- Encrypted tenant identifiers
- Query-level access controls
- Cross-tenant access prevention

Application Level:

- Tenant context validation
- API request filtering
- User session isolation
- Data processing boundaries
- Error message sanitization

Infrastructure Level:

- Network segmentation
- Container isolation
- Resource quotas
- Monitoring separation
- Backup segregation

Access Control Implementation:

Authentication:

- Multi-factor authentication
- SSO integration (SAML/OAuth)
- Certificate-based authentication
- Biometric authentication options
- Session management

Authorization:

- Role-based access control (RBAC)
- Attribute-based access control (ABAC)
- Dynamic access control
- Context-aware permissions
- Temporal access restrictions

Audit and Monitoring:

- Real-time access logging
- Behavioral analytics
- Anomaly detection

- Failed access monitoring
- Privilege escalation alerts

4.2 Encryption Standards

yaml

Encryption at Rest:

Database Encryption:

- Transparent Data Encryption (TDE)
- Customer-managed encryption keys
- Field-level encryption for PHI
- Key rotation (90-day cycle)
- HSM-based key storage

File System Encryption:

- Full disk encryption (AES-256)
- File-level encryption
- Backup encryption
- Archive encryption
- Secure key management

Encryption in Transit:

Network Communication:

- TLS 1.3 for all connections
- Perfect Forward Secrecy (PFS)
- Certificate pinning
- VPN for admin access
- API gateway encryption

Application Layer:

- End-to-end encryption for sensitive operations
- Message queue encryption
- Inter-service communication encryption
- Mobile app data transmission
- Third-party integration encryption

Key Management:

Key Lifecycle:

- Automated key generation
- Secure key distribution
- Regular key rotation
- Key escrow procedures
- Secure key destruction

Key Storage:

- Hardware Security Modules (HSM)
- Google Cloud KMS integration
- Multi-region key replication

- Access control for keys
- Audit logging for key operations

4.3 Data Masking and De-identification

yaml

De-identification Methods:

Safe Harbor Method:

- 18 identifier removal
- Geographic subdivision limitations
- Date shifting procedures
- Age restrictions (89+ years)
- Automated identification scanning

Expert Determination:

- Statistical disclosure control
- Re-identification risk assessment
- Privacy expert certification
- Documentation requirements
- Ongoing risk monitoring

Data Masking Techniques:

Static Data Masking:

- Production data copying
- Format-preserving encryption
- Deterministic masking
- Referential integrity preservation
- Realistic test data generation

Dynamic Data Masking:

- Real-time data obfuscation
- Role-based masking
- Query-level masking
- Context-sensitive masking
- Performance optimization

Synthetic Data Generation:

AI-Generated Data:

- Differential privacy implementation
- Statistical similarity preservation
- Privacy risk assessment
- Utility preservation validation
- Generative model training

Quality Assurance:

- Statistical validation
- Privacy preservation verification
- Utility testing

- Re-identification testing
- Model bias assessment

5. AI/ML Data Governance

5.1 Training Data Management

yaml

Data Preparation:

Data Collection:

- IRB approval for research data
- Patient consent for AI training
- Data provenance tracking
- Quality assessment
- Bias detection and mitigation

Data Preprocessing:

- De-identification verification
- Data standardization
- Feature engineering documentation
- Data lineage tracking
- Version control

Data Validation:

- Statistical validation
- Clinical validation
- Bias assessment
- Privacy preservation verification
- Regulatory compliance check

Model Training Governance:

Ethical Considerations:

- Algorithmic fairness assessment
- Bias detection and mitigation
- Transparency and explainability
- Clinical validation requirements
- Regulatory compliance verification

Technical Controls:

- Federated learning implementation
- Differential privacy application
- Model audit trails
- Performance monitoring
- Security controls

Data Usage Tracking:

Training Data Lineage:

- Source data identification
- Transformation tracking
- Feature derivation documentation
- Model version correlation

- Impact assessment

Model Performance Monitoring:

- Prediction accuracy tracking
- Bias drift detection
- Data drift monitoring
- Model degradation alerts
- Retraining triggers

5.2 AI Model Privacy Protection

yaml

Privacy-Preserving Techniques:

Differential Privacy:

- Privacy budget management
- Noise calibration
- Composition tracking
- Privacy loss accounting
- Utility-privacy trade-offs

Federated Learning:

- Local model training
- Secure aggregation
- Privacy-preserving protocols
- Communication efficiency
- Byzantine robustness

Homomorphic Encryption:

- Encrypted computation
- Privacy-preserving inference
- Secure multi-party computation
- Performance optimization
- Key management

Model Interpretability:

Explainability Requirements:

- Feature importance explanation
- Decision path visualization
- Counterfactual explanations
- Local interpretability
- Global model behavior

Clinical Integration:

- Provider-friendly explanations
- Clinical decision support
- Risk factor identification
- Treatment recommendations
- Confidence intervals

5.3 AI Inference Data Handling

yaml

Real-time Inference:

Data Processing:

- Just-in-time data preparation
- Real-time de-identification
- Privacy-preserving inference
- Result post-processing
- Audit trail generation

Privacy Controls:

- Input data minimization
- Output data filtering
- Temporary data handling
- Memory management
- Secure disposal

Batch Processing:

Large-scale Analysis:

- Population health analytics
- Cohort identification
- Trend analysis
- Quality metrics
- Research insights

Privacy Protection:

- Aggregation techniques
- Statistical disclosure control
- K-anonymity implementation
- L-diversity application
- T-closeness verification

6. Cross-Border Data Transfers

6.1 International Compliance

yaml

GDPR Compliance (European Union):

Lawful Basis:

- Consent management
- Legitimate interest assessment
- Vital interest determination
- Public task identification
- Contract necessity

Data Subject Rights:

- Right to be informed
- Right of access
- Right to rectification
- Right to erasure
- Right to restrict processing
- Right to data portability
- Right to object
- Rights related to automated decision making

Transfer Mechanisms:

- Adequacy decisions
- Standard contractual clauses
- Binding corporate rules
- Certification schemes
- Approved codes of conduct

Other Jurisdictions:

Canada (PIPEDA):

- Privacy impact assessments
- Breach notification requirements
- Consent management
- Third-party processing agreements
- Cross-border transfer restrictions

Asia-Pacific:

- Country-specific requirements
- Data localization laws
- Transfer restriction compliance
- Local representative requirements
- Regulatory notification procedures

6.2 Data Residency Requirements

Geographic Restrictions:

Data Localization:

- Country-specific storage requirements
- Processing location restrictions
- Backup location limitations
- Disaster recovery considerations
- Third-party service compliance

Implementation Strategy:

- Multi-region deployment
- Data classification by geography
- Automated routing rules
- Compliance monitoring
- Audit trail maintenance

Cross-Border Processing:

Legal Framework:

- Transfer impact assessments
- Supplementary measures
- Risk mitigation strategies
- Ongoing monitoring requirements
- Documentation procedures

Technical Implementation:

- Geographic data tagging
- Processing location tracking
- Cross-border access controls
- Encryption for transfers
- Audit logging for transfers

7. Data Quality Management

7.1 Data Quality Framework

yaml

Quality Dimensions:

Accuracy:

- Data validation rules
- Source system verification
- Cross-reference validation
- Clinical validation
- Automated error detection

Completeness:

- Required field validation
- Missing data identification
- Imputation strategies
- Quality scoring
- Completeness reporting

Consistency:

- Format standardization
- Reference data validation
- Cross-system consistency
- Temporal consistency
- Referential integrity

Timeliness:

- Data freshness monitoring
- Update frequency tracking
- Processing time measurement
- Real-time validation
- Staleness detection

Quality Monitoring:

Automated Monitoring:

- Real-time quality checks
- Quality score calculation
- Trend analysis
- Anomaly detection
- Alert generation

Manual Review:

- Periodic quality audits
- Clinical review processes
- Data steward oversight

- Exception investigation
- Corrective action procedures

7.2 Data Stewardship

yaml

Data Steward Roles:

Clinical Data Steward:

- Clinical data validation
- Medical terminology oversight
- Clinical workflow integration
- Provider training
- Quality improvement initiatives

Technical Data Steward:

- Data architecture oversight
- Technical quality monitoring
- System integration management
- Performance optimization
- Security compliance

Business Data Steward:

- Business rule definition
- Process documentation
- User requirement gathering
- Change management
- Stakeholder communication

Governance Processes:

Data Quality Committee:

- Monthly quality reviews
- Quality metrics assessment
- Issue prioritization
- Resource allocation
- Process improvement

Quality Improvement:

- Root cause analysis
- Corrective action planning
- Process optimization
- Training programs
- Technology enhancements

8. Audit and Compliance Monitoring

8.1 Audit Framework

yaml

Audit Types:

Internal Audits:

- Monthly compliance reviews
- Quarterly comprehensive audits
- Annual risk assessments
- Ad-hoc incident investigations
- Process effectiveness reviews

External Audits:

- HIPAA compliance audits
- SOC 2 Type II audits
- ISO 27001 certification
- Regulatory examinations
- Third-party assessments

Audit Scope:

Data Handling:

- Data collection procedures
- Processing activities
- Storage and retention
- Sharing and disclosure
- Destruction procedures

Security Controls:

- Access control effectiveness
- Encryption implementation
- Network security
- Incident response
- Vulnerability management

Privacy Protection:

- Individual rights implementation
- Consent management
- Notice provisions
- Breach response
- Training effectiveness

8.2 Continuous Monitoring

yaml

Automated Monitoring:

Access Monitoring:

- User access patterns
- Privileged account usage
- Failed access attempts
- Data export activities
- Unusual access patterns

Data Processing:

- Processing volume monitoring
- Data quality metrics
- Performance indicators
- Error rate tracking
- Processing time analysis

Compliance Dashboards:

Real-time Indicators:

- Compliance score
- Active incidents
- Audit findings status
- Training completion rates
- Risk assessment results

Trend Analysis:

- Compliance trends over time
- Risk profile changes
- Incident patterns
- Performance improvements
- Cost of compliance

8.3 Reporting and Documentation

yaml

Regular Reports:

Daily Reports:

- Security event summaries
- Data quality alerts
- Access anomalies
- System performance
- Incident status updates

Monthly Reports:

- Compliance dashboard
- Audit findings summary
- Risk assessment updates
- Training metrics
- Performance indicators

Annual Reports:

- Comprehensive compliance review
- Risk assessment results
- Audit summary
- Improvement recommendations
- Regulatory filing requirements

Documentation Requirements:

Policy Documentation:

- Data governance policies
- Privacy procedures
- Security standards
- Incident response plans
- Training materials

Operational Documentation:

- Process workflows
- System configurations
- Audit procedures
- Investigation protocols
- Remediation procedures

9. Incident Response and Breach Management

9.1 Data Breach Response

yaml

Breach Classification:

Breach Types:

- Unauthorized access
- Data theft or loss
- Accidental disclosure
- System compromise
- Third-party breach

Severity Assessment:

- **Low risk:** Limited data, low probability of harm
- **Medium risk:** Moderate data exposure, potential harm
- **High risk:** Extensive data exposure, significant harm
- **Critical:** PHI compromise, immediate harm likely

Response Timeline:

Immediate Response (0-1 hours):

- Incident containment
- Initial assessment
- Team notification
- Evidence preservation
- Legal consultation

Short-term Response (1-24 hours):

- Detailed investigation
- Impact assessment
- Risk analysis
- Notification planning
- Media strategy

Medium-term Response (1-3 days):

- Individual notifications
- Regulatory reporting
- Public disclosure (if required)
- Remediation implementation
- Monitoring enhancement

Long-term Response (3+ days):

- Investigation completion
- Lessons learned
- Process improvements
- Legal proceedings
- Ongoing monitoring

9.2 Notification Requirements

yaml

Individual Notifications:

Timing Requirements:

- **HIPAA:** 60 days from discovery
- **GDPR:** 72 hours to supervisory authority
- **State laws:** Varies by jurisdiction
- **Contract requirements:** As specified

Content Requirements:

- Description of breach
- Types of information involved
- Steps taken to investigate
- Contact information
- Steps individuals can take
- Date of breach and discovery

Regulatory Notifications:

HHS Office for Civil Rights:

- 60 days for breaches affecting 500+ individuals
- Annual report for smaller breaches
- Electronic submission required
- Detailed breach information

State Attorneys General:

- Timing varies by state
- Copy of notification letter
- Breach details and impact
- Remediation measures

Other Regulators:

- FDA (for medical devices)
- FTC (for consumer protection)
- State health departments
- International data protection authorities

9.3 Post-Incident Procedures

yaml

Investigation and Analysis:

Root Cause Analysis:

- Technical failure analysis
- Process breakdown identification
- Human error assessment
- Third-party involvement
- System vulnerability review

Impact Assessment:

- Affected individuals count
- Data types compromised
- Potential harm analysis
- Financial impact
- Reputational damage

Remediation and Prevention:

Immediate Remediation:

- Security control enhancement
- Process improvements
- Staff retraining
- System updates
- Monitoring improvements

Long-term Prevention:

- Policy updates
- Technology upgrades
- Training enhancements
- Audit improvements
- Risk management updates

10. Third-Party Data Sharing

10.1 Business Associate Management

yaml

Business Associate Agreements (BAAs):

Required Provisions:

- Permitted uses and disclosures
- Safeguarding requirements
- Subcontractor provisions
- Individual rights implementation
- Breach notification requirements
- Return or destruction of PHI
- Compliance monitoring

Due Diligence:

- Security assessment
- Privacy policy review
- Compliance history
- Financial stability
- References verification
- Ongoing monitoring

Data Sharing Controls:

Technical Safeguards:

- Secure transmission protocols
- Access control implementation
- Audit logging
- Data encryption
- Data loss prevention

Administrative Controls:

- Data sharing agreements
- Purpose limitation
- Minimum necessary principle
- Training requirements
- Monitoring procedures

10.2 Research Data Sharing

yaml

Research Partnerships:

IRB Approval:

- Research protocol review
- Privacy protection assessment
- Risk-benefit analysis
- Consent form approval
- Ongoing oversight

Data De-identification:

- Safe Harbor compliance
- Expert determination
- Re-identification risk assessment
- Limited data set creation
- Data use agreements

Researcher Training:

- Privacy protection training
- Data handling procedures
- Security requirements
- Compliance obligations
- Incident reporting

Clinical Trial Data:

Regulatory Compliance:

- FDA regulations (21 CFR Part 11)
- GCP compliance
- ICH guidelines
- Data integrity requirements
- Audit trail maintenance

Data Sharing:

- ClinicalTrials.gov requirements
- Data transparency initiatives
- Publication requirements
- IP protection
- Commercial considerations

11. Implementation Roadmap

11.1 Phase 1: Foundation (Months 1-2)

yaml

Policy Development:

- Data governance framework establishment
- Privacy policy development
- Security standards definition
- Consent management procedures
- Incident response planning

Technical Implementation:

- Data classification system
- Encryption implementation
- Access control deployment
- Audit logging activation
- Monitoring system setup

11.2 Phase 2: Enhancement (Months 3-4)

yaml

Advanced Controls:

- AI/ML governance implementation
- Cross-border compliance setup
- Data quality monitoring
- Privacy-preserving techniques
- Third-party integration controls

Operational Excellence:

- Staff training completion
- Process optimization
- Compliance monitoring
- Audit procedures
- Continuous improvement

11.3 Phase 3: Optimization (Months 5-6)

yaml

Continuous Improvement:

- Performance optimization
- Process refinement
- Technology upgrades
- Compliance enhancement
- Stakeholder feedback integration

Certification Preparation:

- External audit preparation
- Documentation completion
- Control testing
- Gap remediation
- Certification maintenance

12. Training and Awareness

12.1 Staff Training Program

yaml

Role-Based Training:

All Staff:

- HIPAA fundamentals
- Privacy awareness
- Security basics
- Incident reporting
- Data handling procedures

Technical Staff:

- Data security implementation
- Privacy-preserving techniques
- Incident response procedures
- Audit requirements
- System administration

Clinical Staff:

- Patient privacy rights
- Consent management
- Clinical data handling
- Quality requirements
- Ethical considerations

Management:

- Governance oversight
- Risk management
- Compliance monitoring
- Decision-making authority
- Stakeholder communication

12.2 Ongoing Education

yaml

Training Delivery:

Initial Training:

- New hire orientation
- Role-specific training
- Hands-on practice
- Competency assessment
- Certification completion

Ongoing Training:

- Annual refresher training
- Quarterly updates
- Policy change training
- Incident-based training
- Continuous education

Assessment and Certification:

Competency Testing:

- Knowledge assessments
- Practical exercises
- Scenario-based testing
- Regular re-certification
- Performance monitoring

Documentation:

- Training records
- Certification tracking
- Performance metrics
- Improvement plans
- Compliance reporting

13. Appendices

Appendix A: Data Classification Templates

Appendix B: Consent Form Templates

Appendix C: Business Associate Agreement Template

Appendix D: Incident Response Playbooks

Appendix E: Audit Checklists and Procedures
